

Secure Micro-Segmentation Report

Name: Solomon Mwaura

Date: March 15, 2026

Role: Junior Cybersecurity Engineer

1.0 Segmentation Plan and Micro-Segmentation Goals

Planned Security Zones & Segmentation Strategy

To implement a Zero Trust architecture, the network is divided into the following functional zones:

- **Finance Zone (192.168.1.0/24):** Contains sensitive financial data and logs (Finance-VM, Finance-VM2).
- **HR/Database Zone (192.168.2.0/24 & 192.168.3.0/24):** Contains employee records and backend databases (HR-VM, DB-VM).
- **Audit Zone (192.168.4.0/24):** A restricted segment for third-party vendor access (Audit-VM).

How segmentation contributes to security: It restricts the "blast radius" of a potential breach. By isolating these segments, a compromise in the Audit zone does not grant automatic lateral movement into the Finance or DB zones.

Micro-Segmentation Goals and Access Controls

The primary goal is **Least Privilege Access**.

- **Criticality:** Standard firewalls often allow all internal traffic. Micro-segmentation ensures that even internal devices only talk to what they absolutely must.
- **Logging Enhancement:** Logging denied attempts provides the SOC with "indicators of compromise" (IoCs), allowing us to see if an auditor is attempting to probe unauthorized database servers.

2.0 Firewall Rules and Network Traffic Control

Firewall Configuration and Implementation

The VyOS router was configured using zone-based firewalling. We defined a specific policy for the third-party Audit-VM to ensure it can only reach the Syslog port (UDP 514) on the Finance server.

Table of Implemented Rules

Rule Name	Source IP/Subnet	Destination IP/Subnet	Protocol	P	Action
AUDIT-ALLOW	192.168.4.2	192.168.1.2	UDP	5	Accept
AUDIT-DENY-FIN	192.168.4.2	192.168.1.0/24	Any	A	Drop
AUDIT-DENY-DB	192.168.4.2	192.168.3.0/24	Any	A	Drop
LOG-DROP	Any	Any	Any	A	Drop + Log

3.0 Traffic Validation and Analysis

Network Connectivity Tests

- **Success:** The command `logger -n 192.168.1.2 -P 514 "Audit test message"` successfully appeared in the Finance-VM syslog after enabling `imudp` in `rsyslog.conf`.
- **Blocked:** Pings from Audit-VM to DB-VM (192.168.3.2) failed as expected.
- **Resolution:** Initially, logs weren't appearing; I had to restart the `rsyslog` daemon on Finance-VM to listen on the network interface.

Capturing and Analyzing Traffic

Using `show log | match DROP` on the VyOS router, I confirmed that unauthorized ICMP and TCP attempts from the Audit-VM were being caught by Rule 99.

Example Captured Data:

```
[Mar 15 21:45:12] AUDIT-to-FIN-DROP: IN=eth3 OUT=eth1 SRC=192.168.4.2  
DST=192.168.3.2 PROTO=ICMP TYPE=8 CODE=0
```

4.0 Threat Modeling and Risk Analysis

Identifying Vulnerabilities Before Segmentation

1. **Lateral Movement Path:** Without micro-segmentation, a compromised vendor credential on Audit-VM could be used to RDP or SSH into the Database server.
2. **Insecure Service Exposure:** If the Finance-VM is not hardened, an attacker could attempt to exploit other services (like HTTP/SMB) if the firewall isn't restricted to port 514.

Assessing Network Security Risks

- **Critical Assets:** The **DB-VM** (proprietary data) and **Finance-VM** (financial integrity).
- **Mitigation:** By applying an explicit `DROP` rule after the `ALLOW` rule for syslog, we close the vector for unauthorized protocol usage.

Applying Threat Modeling (STRIDE)

- **Information Disclosure (STRIDE):** AuditCorp should only see logs. Without port-specific rules, they could potentially browse file shares.
 - **Lateral Movement:** The `ZERO-TRUST` rule 99 prevents an attacker from moving from the Audit zone to the HR zone.
-

5.0 Reflection on Security Implementation

Effectiveness of Micro-Segmentation

The rules successfully enforced the "Identity-Based" perimeter. Even though the Audit-VM is "on the network," it is effectively in a digital cage, able to see only one port on one specific server.

Challenges and Adjustments

The main challenge was ensuring the destination server (Finance-VM) was actually listening for the traffic. Security is a two-way street: the firewall must allow it, and the host must be configured to receive it securely.

Future Security Enhancements

- **Automation:** Implement **fail2ban** or an IPS (Intrusion Prevention System) to automatically null-route any IP that triggers more than 5 "DENY" logs in a minute.
 - **Encryption:** Upgrade from standard Syslog (UDP 514) to TLS-encrypted Syslog (TCP 6514) to prevent sniffing of log data in transit.
-

6.0 Broader Security Implications

Micro-segmentation is the cornerstone of **Zero Trust**. It moves security from the "castle-and-moat" (big perimeter) to "safety deposit boxes" (individual asset protection). In the real world, this prevents ransomware from spreading across an entire data center, as the malware would be blocked the moment it tries to scan a different segment.

-